WYDZIAŁ ELEKTRONIKI I TECHNIK INFORMACYJNYCH

Podstawy cyberbezpieczeństwa (PCYB)

Projekt - Faza 1

Pioruny Pioruna

Kierunek: Telekomunikacja

Jakub Surma 327768

Albert Kołsut 331493

Kajetan Wilkowski 31542

25Z

17 listopada 2025, Warszawa

Spis treści

1. Zadanie do wykonania 2
2. Opis merytoryczny wybranej techniki ataku 2
3. Opis środowiska 2
4. Przebieg ataku 2
5. Opis załączników 8
6. Podsumowanie i wnioski 8

1. Zadanie do wykonania

Celem pierwszej fazy było przygotowanie realizacji technicznej i opracowanie współczesnego ataku jedno lub wieloetapowego, tzn. zaprojektowanie środowiska, przeprowadzenie symulacji ataku i zebranie całego możliwego zestawu informacji świadczącej o podejmowanych działaniach oraz wyciągnięcie z całości odpowiednich wniosków.

2. Opis merytoryczny wybranej techniki ataku

Celem naszego projektu było przejęcie komputera należącego do pracownika fikcyjnej firmy. Atak rozpoczęliśmy od wysłania maila phishingowego do pracownika. Wiadomość zawierała informację o rzekomym problemie z przedłużeniem subskrypcji bazy danych. Po kliknięciu w link pracownik został przekierowany na przygotowaną wcześniej stronę logowania. Podane przez niego dane logowania zostały przez nas zapisane.

W projekcie korzystaliśmy z darmowej bazy danych MySQL. Następnie wykorzystaliśmy zdobyte dane logowania, aby uzyskać dostęp do bazy zawierającej zahashowane loginy i hasła pracowników firmy. Przy pomocy narzędzia do łamania hashy odzyskaliśmy część z nich.

W kolejnym kroku sprawdziliśmy komputer jednego z pracowników, aby ustalić, czy którykolwiek z portów był otwarty. Po wykryciu otwartego portu SSH połączyliśmy się z komputerem, używając wcześniej zdobytego loginu i hasła. W ten sposób uzyskaliśmy dostęp do komputera pracownika.

W projekcie wykorzystywane były techniki takie jak phishing oraz łamanie haseł metodą brute force. Zgodnie z kalsyfikacją MITRE ATT&CK wykorzystaliśmy następujące metody:
— T1566.002 - Phishing: Spearphishing
— T1110.002 - BruteForce: Password Cracking
— T1046 - NetworkServiceScanning
— T1021.004 - RemoteServices: SSH

3. Opis środowiska

Jako że nasz atak składa się z kilku etapów wykorzystaliśmy różne narzędzia i środowiska do zobrazowania go. Komputery atakującego i ofiary to przygotowane przez nas maszyny wirtualne z zainstalowanym systemem Debian. Zostały one specjalnie przygotowane na potrzeby projektu oraz tylko my mieliśmy do niech dostęp więc były one bezpiecznym środowiskiem do przeprowadzenia ataku.

Do stworzenia maila phisingowego wykorzystaliśmy kreator maili na stronie Mailjet, dzięki czemu mail wyglądał bardziej wiarygodnie co jest ważne ponieważ ma on za zadanie oszukać ofiarę o swojej autentyczności.

Jako bazę danych wykorzystaliśmy darmową wersję MySQL, jest ona wystarczająca by zaprezentować przeprowadzenie ataku.

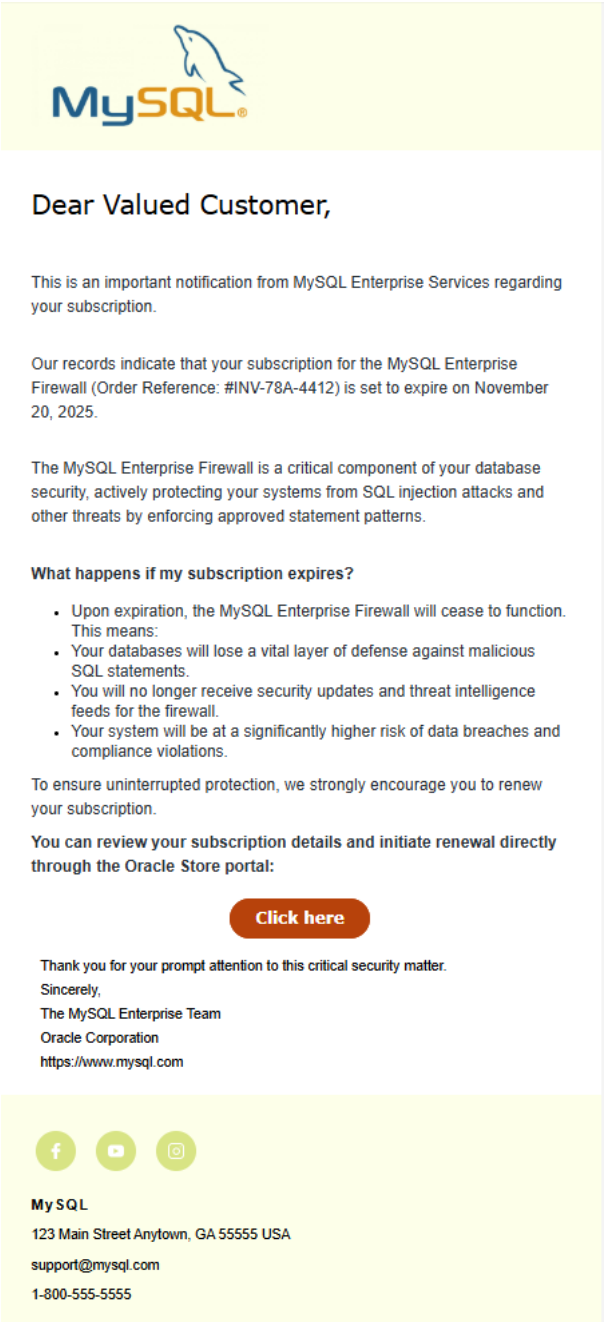
Stronę internetową podszywającą się pod stronę logowania napisaliśmy w języku Python wykorzystując narzędzie Djnago oraz bazę danych MySQL.

Ostatnim wykorzystanym narzędziem był prosty skrypt napisany przez nas w Pythonie służący tworzenia i łamania hashy.

W całym projekcie wykorzystujemy dość proste narzędzia, lecz są one wystarczające do zobrazowania w jaki sposób można by było przeprowadzić wieloetapowy atak i jakich zachowań powinniśmy się wystrzegać by nie zostać ofiarami takiego ataku.

4. Przebieg ataku

Atak rozpoczęliśmy od wysłania maila phisingowego. Mail zawierał informację o tym, że kończy się subskrypcja odpowiedzialna za bezpieczeństwo bazy danych MySQL. Mail zawierał link który przenosił do strony podszywającej się pod stronę logowania firmy Oracle, która jest właścicielem baz danych MySQL. Na potrzeby projektu przyjęliśmy że pracownik, który otrzymał maila dał się oszukać i wszedł w podpięty link.



Dear Valued Customer,

This is an important notification from MySQL Enterprise Services regarding your subscription.

Our records indicate that your subscription for the MySQL Enterprise Firewall (Order Reference: #INV-78A-4412) is set to expire on November 20, 2025.

The MySQL Enterprise Firewall is a critical component of your database security, actively protecting your systems from SQL injection attacks and other threats by enforcing approved statement patterns.

What happens if my subscription expires?

- Upon expiration, the MySQL Enterprise Firewall will cease to function. This means:
- Your databases will lose a vital layer of defense against malicious SQL statements.
- You will no longer receive security updates and threat intelligence feeds for the firewall.
- Your system will be at a significantly higher risk of data breaches and compliance violations.

To ensure uninterrupted protection, we strongly encourage you to renew your subscription.

You can review your subscription details and initiate renewal directly through the Oracle Store portal:

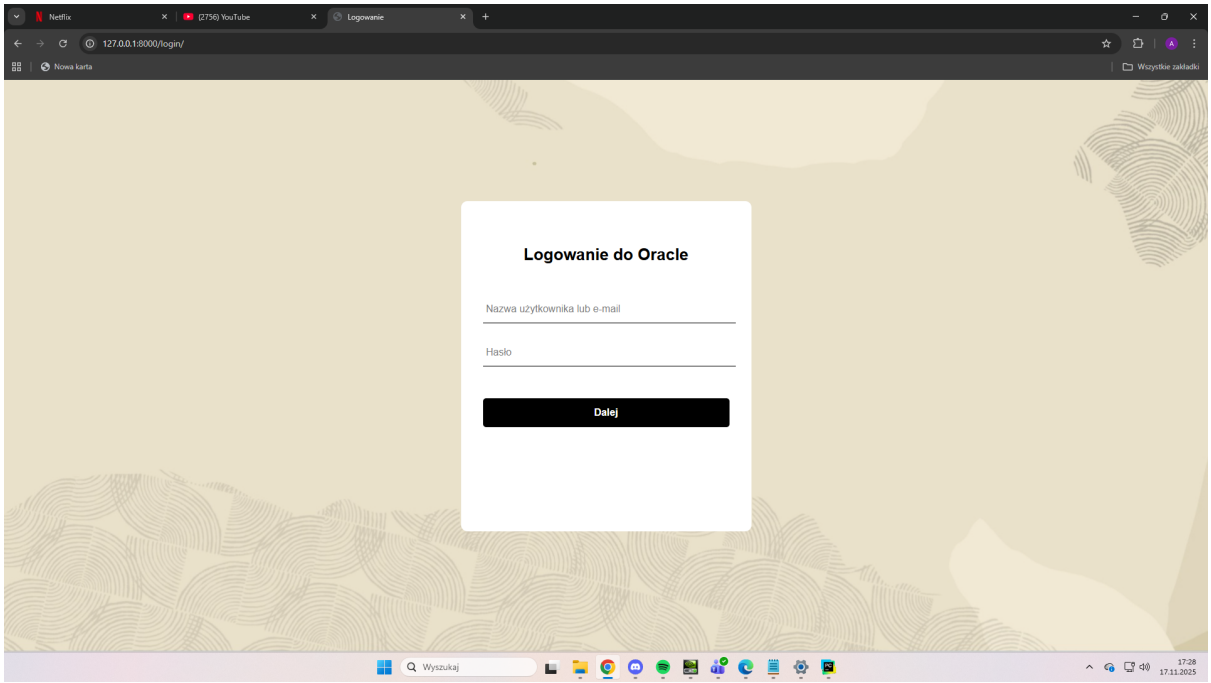
Click here

Thank you for your prompt attention to this critical security matter.
Sincerely,
The MySQL Enterprise Team
Oracle Corporation
https://www.mysql.com

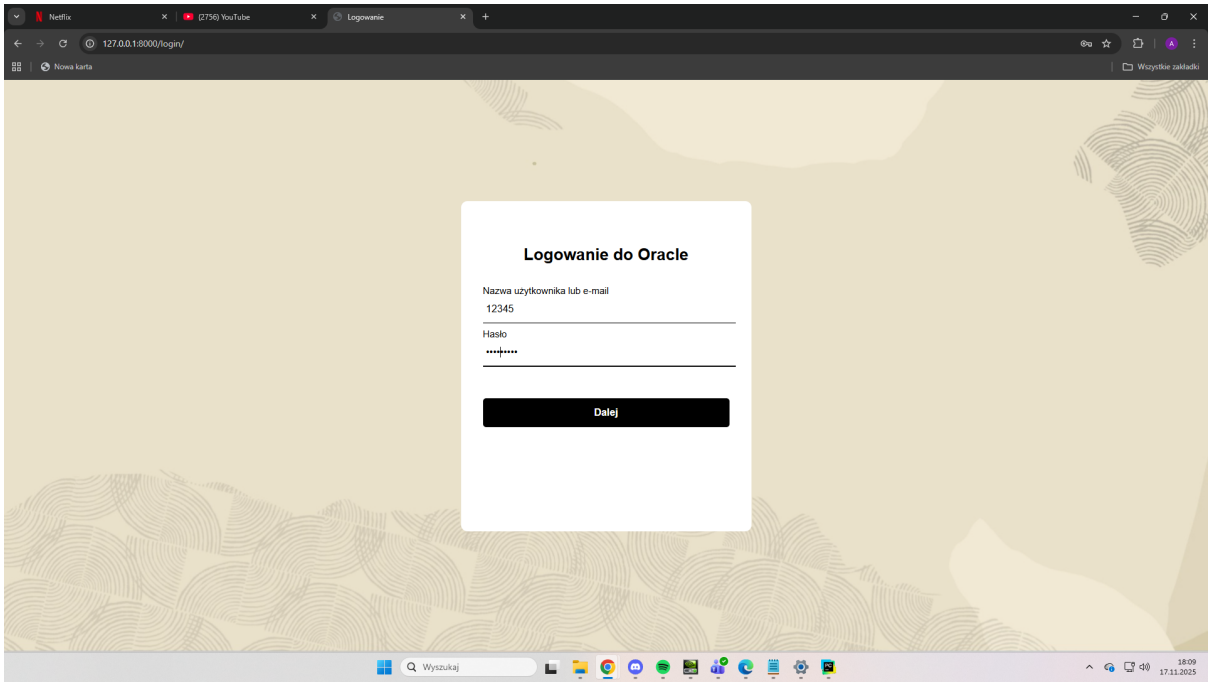
MySQL
123 Main Street Anytown, GA 55555 USA
support@mysql.com
1-800-555-5555

Rysunek 1. Treść maila phisingowego

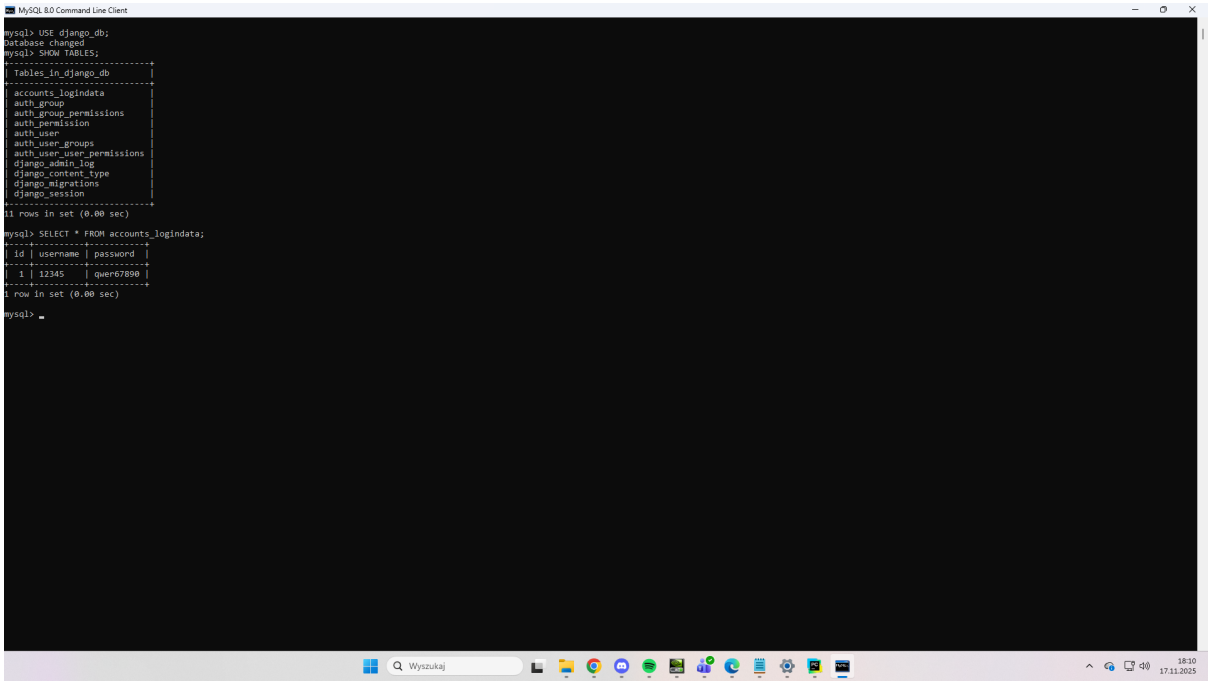
Po wejściu w podany link przenosi nas do wcześniej wspomnianej strony. Tworząc ją staraliśmy się by przypominała stronę logowania firmy Oracle, by podobnie jak mail uwiarygodnić ją. Pracownik chcąc się zalogować na stronie podał swój login i hasło. Strona zapisuje w wewnętrznej bazie danych podane informację a użytkownik otrzymuje informację że podał błędne dane. W ten sposób uzyskaliśmy hasło i login do bazy danych firmy, która będzie dalszym celem naszego ataku.



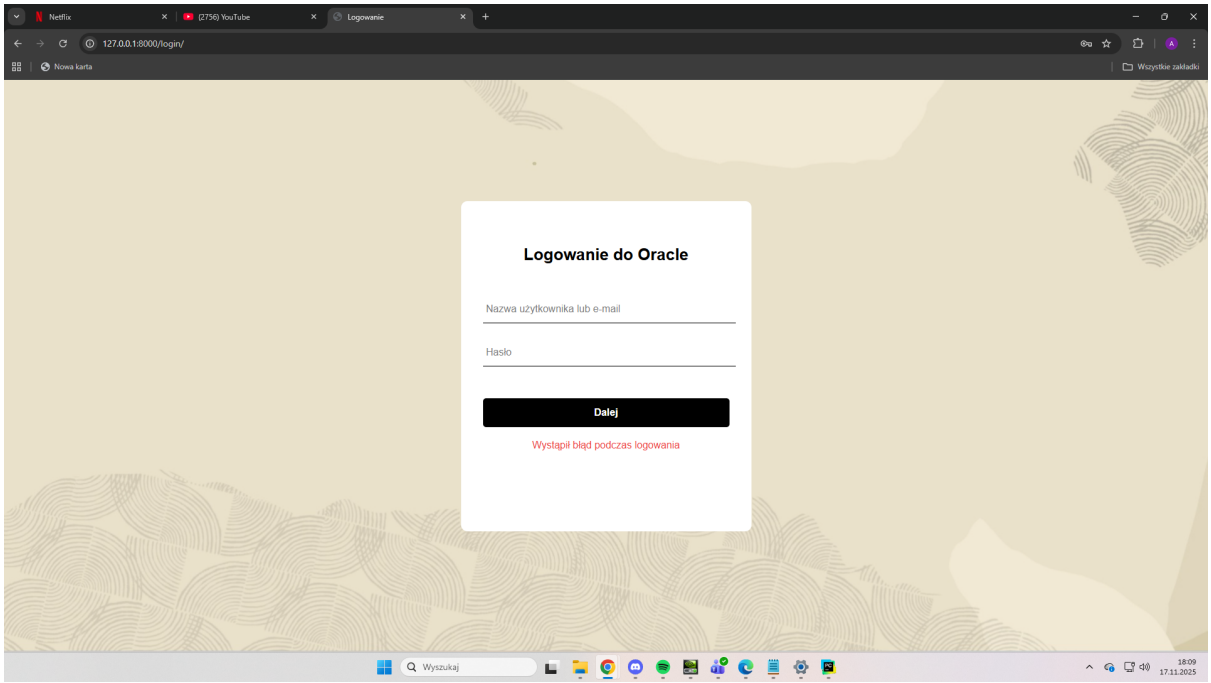
Rysunek 2. Strona logowania



Rysunek 3. Strona logowania: wpisane hasło i login

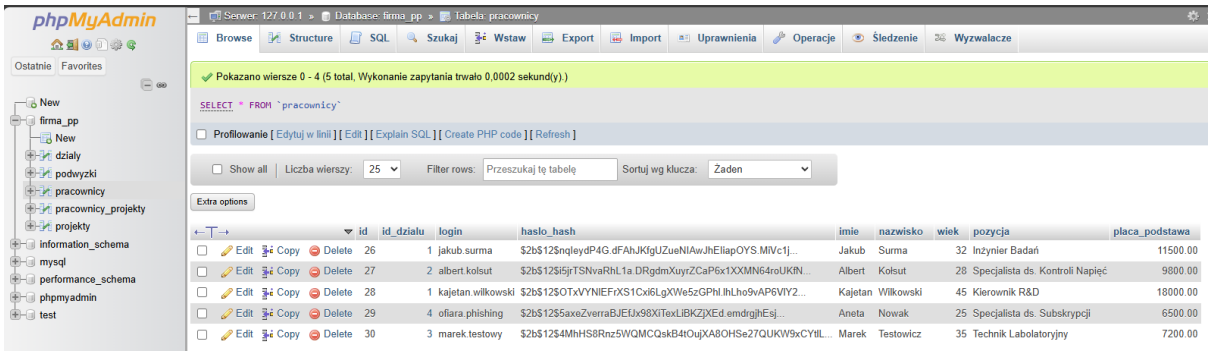


Rysunek 4. Hasło i login zapisane przez stronę



Rysunek 5. Informacja zwrotna

Zdobyte login i hasło wykorzystujemy następnie w prawdziwej bazie danych MySQL. Uzyskaliśmy dzięki temu dostęp do wewnętrznych danych firmy. Według założeń projektu interesuje nas jednak bezpośredni dostęp do komputera pracownik firmy, więc z bazy danych szukamy loginy i hasła do komputerów firmowych. Informacje takie znajdują się w firmowej bazie danych w formie hashy. Zapisujemy je ponieważ wykorzystamy je w kolejnym kroku. W naszym ataku wykorzystamy login i hasło pracowniczki Anety Nowak.



Rysunek 6. Baza danych wraz z loginami i hasłami

Zdobyte przez nas hasło jest zahasowane, do złamania go wykorzystaliśmy prosty skrypt w Pythonie. Jest to bardzo prosta wersja programu wykorzystującego atak słownikowy. Zamiast zgadywać wszystkie możliwe kombinacje (co zajęłoby bardzo dużo czasu), sprawdza on jedynie hasła które ma zapisane. U nas wpisanych jest tylko kilka haseł lecz w profesjonalnych programach wykorzystuje się listy z najczęściej używanymi hasłami np. Rock You password list. Na rzecz naszego projektu założyliśmy że hasło znajduje się w słowniku i zostało złamane.

```
--- START ŁAMANIA HASEŁ BCrypt (Symulacja Password Cracking) ---

[!] Próba łamania hasha dla użytkownika: ofiara.phishing
  [+] ZŁAMANO! Login: ofiara.phishing -> Hasło: zaq1@WSX

--- PODSUMOWANIE ATKU CRACKINGU (T1110.002) ---
Próbowano złamać 1 hashy.
Złamano: 1

--- ZŁAMANE KONTO I ZDOBYTE HASŁO DO DALSZYCH ATAKÓW ---
Login: ofiara.phishing, Hasło: zaq1@WSX

Process finished with exit code 0
```

Rysunek 7. Wynik łamania hasha

Ostatnią częścią ataku było połączenie się z komputerem ofiary. Zaczęliśmy od przeskanowania sieci przy pomocy narzędzia **nmap**.

```
iplabs@debian:~$ nmap 192.168.1.1-255
```

Rysunek 8. Komenda nmap

```
Nmap scan report for 192.168.1.144
Host is up (0.0025s latency).
Not shown: 999 closed tcp ports (conn-refused)
PORT     STATE SERVICE
3389/tcp open  ms-wbt-server
```

Rysunek 9. Wynik komendy nmap

Jak widzimy komputer ofiary miał otwarty port 3389. Jest to port używanym do nawiązywania zdalnych połączeń z komputerami i serwerami Windows. Często się zdarza że ludzie zapominają go zabezpieczyć i pozostaje on otwarty. Wykorzystaliśmy otwarty port do zainicjowania połączenia ssh z komputerem ofiary. Do logowania wykorzystaliśmy zdobyte wcześniej login i hasło.

```
iplabs@debian:~$ ssh ofiaraphishing@192.168.1.144 -p 3389
ofiaraphishing@192.168.1.144's password:
Linux debian 6.12.48+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.48-1 (2025-
9-20) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Tue Nov 18 07:48:03 2025 from 192.168.1.144
ofiaraphishing@debian:~$ ls
WrażliweDaneFirmowe.txt
```

Rysunek 10. Połączenie ssh

Dało nam to pełen dostęp do komputera co uznaliśmy za wystarczające by uznać że atak został przeprowadzony z sukcesem.

```
ofiaraphishing@debian:~$ cat WrażliweDaneFirmowe.txt
Atak zakończył się sukcesem
```

Rysunek 11.

5. Opis załączników

Razem z raportem wysłane wykorzystane w ataku pliki:
— **Folder Strona** - pliki przygotowanej przez nas strony logowania
— **hash.py** - program w Pythonie, z którego pomocą hashowaliśmy hasła
— **dehash.py** - program w Pythonie, z którego pomocą łamaliśmy hashe
— **firma_pp.sql** - kod zrobionej przez nas bazy danych

6. Podsumowanie i wnioski

Przeprowadzony wieloetapowy atak wykazał, jak skuteczne może być połączenie technik inżynierii społecznej z wykorzystaniem luk w zabezpieczeniach technicznych. Atak rozpoczął się od prostego phishingu, który okazał się wystarczający do uzyskania poufnych danych uwierzytelniających. Ataki tego typu są bardzo popularne więc każdy powinien być świadomy o tym jakie zagrożenie niosą. Następne części ataku wskazują jak ważne jest by odpowiednio zabezpieczać wrażliwe dane przechowywane w bazach danych, jak ważne jest posiadanie mocnego hasła(hash takiego hasła nie będzie łamany z taką łatwością) oraz jak ważne jest zabezpieczanie sieci by nie pozwolić na dostęp do naszych komputerów. Całość również pokazało że ataki hakerskie to często złożone procesy wymagające wieloetapowych działań a nie tylko pojedyncze wgranie złośliwego oprogramowania lub kradzież hasła. Z projektu uzyskaliśmy wiedzę o tym czym charakteryzują się ataki, jak szeroki może być ich zakres i jak ważne jest by cała infrastruktura była dobrze zabezpieczona.